

ESSENTIAL BANK

Plan de Continuité d'Activité

Plan de Continuité d'Activité (PCA)

Cours : Infrastructure IT – Gouvernance, Audit et Risques
EFREI Paris | Année universitaire 2025-2026

Mai 2026

Document confidentiel – Usage pédagogique

I. Contexte et lancement du Plan de Continuité d'Activité

Ce premier volet du Plan de Continuité d'Activité d'Essential Bank pose les fondations méthodologiques de la démarche : définition du périmètre d'application, identification des activités essentielles de chaque direction et constitution de l'équipe projet chargée de piloter l'ensemble du processus.

I.1 Périmètre du PCA : analyse organisationnelle, fonctionnelle et géographique

Essential Bank est un établissement bancaire de droit français, créé en novembre 2025 et implanté à Bagnole. Sa mission est d'accompagner les petites entreprises dans leur développement global à travers une offre de services financiers accessibles : création de comptes, octroi de crédits et réalisation de virements. L'entreprise compte 30 collaborateurs répartis sur un siège social et trois agences physiques, s'appuyant sur des technologies cloud (Microsoft Azure) et IoT.

Analyse organisationnelle

Essential Bank se structure en cinq directions placées sous l'autorité de la Direction Générale : la Direction des Ressources Humaines (DRH), la Direction Administrative et Financière (DAF), la Direction Marketing et Communication, et la Direction Informatique. Chaque service compte environ cinq collaborateurs. Les rôles clés identifiés sont : Directeur Général (DG), Directeur Administratif et Financier (DAF), Directeur des Ressources Humaines (DRH), Directeur des Systèmes d'Information (DSI), Responsable de la Sécurité des Systèmes d'Information (RSSI) et Délégué à la Protection des Données (DPO). Les principaux partenaires et prestataires sont la Banque de France, BPI France, PayPal, Stripe, Orange Business et Microsoft Azure.

Analyse fonctionnelle

Les services d'Essential Bank reposent intégralement sur un système d'information centralisé hébergé en cloud. Les opérations bancaires ouverture de comptes, crédits, virements transitent par ce même SI, quel que soit le canal (en ligne ou en agence). L'objectif de l'organisme est de garantir la disponibilité et la sécurité de ces services dans le respect du cadre réglementaire applicable : RGPD, DORA, ISO 27001, RGS, SecNumCloud, HDS et RIA.

Analyse géographique

Essential Bank dispose de quatre sites : le siège de Bagnole et trois agences physiques. L'infrastructure informatique étant hébergée sur Azure et totalement centralisée, l'ensemble des sites partage la même dépendance au système d'information. Un incident majeur sur l'infrastructure cloud aurait un impact simultané sur la totalité des sites.

Décision : périmètre d'un PCA unique

Un Plan de Continuité d'Activité unique est retenu pour l'ensemble d'Essential Bank. La taille réduite de l'organisation (30 personnes), la forte interdépendance entre les directions et la centralisation du système d'information sur Azure rendent inappropriée la création de plusieurs plans distincts. Ce PCA unique couvrira l'intégralité des quatre sites, toutes les directions et l'ensemble des processus bancaires, avec des procédures de repli inter-agences en cas d'indisponibilité d'un site.

I.2 Activités essentielles par direction et objectifs associés

L'analyse de l'organigramme d'Essential Bank permet d'identifier, pour chaque direction, les activités essentielles au fonctionnement de l'entreprise, leur appartenance ou non au cœur de métier, ainsi que les enjeux liés à leur éventuelle interruption.

Direction	Activités essentielles	Cœur de métier	Objectifs et enjeux en cas d'interruption
Direction Générale (DG)	– Pilotage stratégique de l'entreprise – Prises de décisions et arbitrages en situation de crise – Relations institutionnelles (Banque de France, BPI France) – Représentation légale de l'établissement	NON	Son non-fonctionnement paralyse l'ensemble de l'organisation : aucune décision stratégique ne peut être prise, le PCA ne peut être activé et les arbitrages critiques sont bloqués.
Direction des Ressources Humaines (DRH)	– Gestion administrative du personnel et des paies – Mobilisation et déploiement des équipes en situation de crise – Recrutement et maintien des compétences critiques	NON	La DRH constitue le pilier humain du PCA. Son non-fonctionnement entraîne un manque de personnel qualifié sur les postes critiques, compromettant la capacité à maintenir les services bancaires.
Direction Administrative et Financière (DAF)	– Gestion comptable et suivi de trésorerie – Reporting réglementaire obligatoire (Banque de France) – Règlement des prestataires critiques (Azure, Stripe, PayPal)	PARTIEL	Partiellement au cœur de métier : son interruption expose Essential Bank à des sanctions réglementaires et compromet le paiement des prestataires cloud, risquant un arrêt en cascade des services.
Direction Marketing et Communication	– Gestion de la relation client (B2B et B2C) – Communication de crise auprès des clients et partenaires – Acquisition et fidélisation de la clientèle	NON	Non directement bancaire, mais critique en situation de crise : une communication défaillante lors d'une interruption peut provoquer une perte de confiance massive et des départs de clientèle.
Direction Informatique (DSI / RSSI / DPO)	– Administration du SI et du core banking (application critique) – Gestion de l'infrastructure IT (serveurs, réseaux VLAN)	OUI	Activité entièrement au cœur de métier : toute l'offre bancaire repose sur le SI. Un arrêt entraîne une interruption totale des services (comptes, crédits, virements) et une violation potentielle de DORA et du RGPD.

Direction	Activités essentielles	Cœur de métier	Objectifs et enjeux en cas d'interruption
	– Sécurité des systèmes et gestion des incidents (RSSI) – Conformité RGPD et protection des données (DPO) – Gestion des sauvegardes et du Plan de Reprise d'Activité		

Légende : **OUI** = Cœur de métier | **PARTIEL** = Partiellement au cœur de métier | **NON** = Support essentiel au PCA

I.3 Désignation du chef de projet et constitution de l'équipe PCA

Dans une banque numérique comme Essential Bank, dont la continuité d'activité repose quasi intégralement sur son système d'information, le Directeur des Systèmes d'Information (DSI) est désigné chef de projet PCA. Il dispose de la vision technique et transversale nécessaire pour coordonner l'ensemble de la démarche.

Rôle dans l'équipe PCA	Fonction	Justification et responsabilités dans le cadre du PCA
Chef de projet PCA	DSI	Pilote l'ensemble du projet PCA : coordination de l'analyse des risques, supervision de la rédaction des procédures de continuité et organisation des exercices de test. Son positionnement transversal sur l'ensemble du SI garantit la cohérence technique, opérationnelle et réglementaire de la démarche.
Référent Sécurité	RSSI	Identifie et qualifie les risques cyber, définit les mesures de sécurité en mode dégradé et gère les incidents pendant la crise. Garantit la conformité du PCA avec les exigences du règlement DORA en matière de résilience opérationnelle numérique.
Référent Conformité et Données	DPO	Veille à ce que les procédures de continuité ne compromettent pas la protection des données personnelles des clients. Assure la notification à la CNIL en cas de violation et contrôle les transferts de données vers les environnements de reprise.
Référent Financier et Réglementaire	DAF	Évalue l'impact financier des scénarios de sinistre. Assure la continuité du reporting réglementaire auprès de la Banque de France et le maintien des paiements critiques aux prestataires cloud en période de crise.
Référent Ressources Humaines	DRH	Gère la mobilisation du personnel en crise, désigne les suppléants pour les postes critiques et organise le travail en mode dégradé (télétravail, redéploiement inter-agences). Assure la communication interne auprès des équipes.

Rôle dans l'équipe PCA	Fonction	Justification et responsabilités dans le cadre du PCA
Sponsor et Décideur	DG	Valide les orientations stratégiques du PCA, arbitre les décisions budgétaires, déclare officiellement l'état de crise et représente Essential Bank auprès des partenaires institutionnels (Banque de France, BPI France) lors d'un sinistre majeur.

II. Évaluation du besoin de continuité

Ce second volet identifie et formalise les besoins de continuité d'Essential Bank. Pour chaque activité essentielle définie en Section I, nous décrivons les processus mis en œuvre, les ressources critiques associées, le niveau de service minimum acceptable, les objectifs de reprise (DIMA et RTO), les modes dégradés applicables et les conséquences d'une interruption.

II.1 Processus par activité essentielle et ressources critiques

Pour chaque activité essentielle, deux à trois processus clés sont identifiés ainsi que les ressources critiques dont ces processus dépendent (ressources informatiques, humaines, matérielles et partenariales).

Direction	Processus	Ressources critiques
Direction Générale	P1 – Gouvernance et décision stratégique	Outil de visioconférence (Teams), messagerie sécurisée, accès documents stratégiques (Azure SharePoint), téléphone mobile DG
	P2 – Communication institutionnelle et gestion de crise	Kit de communication de crise pré-rédigé, contacts institutionnels (Banque de France, BPI France), réseaux sociaux, site web Essential Bank, téléphones mobiles de secours
	P3 – Engagement contractuel et représentativité légale	Système de signature électronique, accès aux contrats et documents juridiques, messagerie professionnelle sécurisée
Direction des Ressources Humaines	P1 – Gestion de la paie et des contrats de travail	Logiciel de paie (Sage Paie ou équivalent cloud), SIRH, connexion bancaire pour virements de salaires, imprimante de secours pour bulletins
	P2 – Mobilisation des équipes en situation de crise	Annuaire de crise (contacts personnels des collaborateurs), téléphones mobiles, plan de redéploiement inter-agences, liste des suppléants pour les postes critiques
	P3 – Administration des ressources humaines courante	SIRH (gestion des congés et absences), messagerie interne, documents administratifs RH

Direction	Processus	Ressources critiques	
Direction Administrative et Financière	P1 – Trésorerie et règlements critiques	Accès bancaire en ligne (Banque de France, banques partenaires), logiciel de comptabilité (Cegid ou équivalent), contrats prestataires (Azure, Stripe, Orange Business)	
		P2 – Reporting réglementaire Banque de France	Portail de reporting Banque de France (ONEGATE), logiciel de gestion financière, données comptables consolidées, messagerie sécurisée
		P3 – Comptabilité et contrôle de gestion	Logiciel de comptabilité, fichiers Excel de secours (hors ligne), accès aux données de transactions
Direction Marketing et Communication	P1 – Gestion de la relation client (B2B et B2C)	CRM client, plateforme d'emailing et SMS, standard téléphonique des agences, portail client en ligne	
		P2 – Communication de crise	Kit de communication de crise pré-rédigé, comptes de réseaux sociaux (LinkedIn, X), base de contacts clients (email et SMS), téléphone mobile de secours du responsable communication
		P3 – Campagnes d'acquisition et de fidélisation	Plateforme marketing (emailing, publicité en ligne), base de données prospects, site web Essential Bank, budget marketing disponible
Direction Informatique	P1 – Exploitation et disponibilité du SI (core banking et APIs de paiement)	Serveurs Azure (cloud Microsoft), APIs Stripe et PayPal, infrastructure réseau VLAN inter-agences, application de gestion des comptes et transactions, Orange Business (connectivité réseau), équipe DSI	
		P2 – Gestion de la sécurité et réponse aux incidents (RSSI)	Système SIEM et EDR (détection d'incidents), pare-feu et équipements ASA Cisco, journaux

Direction	Processus	Ressources critiques	
			d'événements système (logs), procédures de réponse aux incidents (PSSI), contact ANSSI / CERT
		P3 – Sauvegarde, reprise et protection des données (DPO et PRA)	Sauvegardes Azure (instantanés toutes les 6 heures), PRA documenté et testé, registre des traitements RGPD, procédures de notification CNIL, environnement de reprise validé

II.2 Niveau de service minimum (NSM) et objectifs de reprise (DIMA / RTO)

Le Niveau de Service Minimum (NSM) définit le seuil en dessous duquel l'indisponibilité du processus devient inacceptable pour l'organisation. La Durée d'Interruption Maximale Admissible (DIMA) représente le temps maximum tolérable avant impact critique ; le Recovery Time Objective (RTO) est l'objectif de rétablissement à atteindre.

Processus	Niveau de service minimum	DIMA	RTO	Justification
Direction Générale (DG)				
P1 – Gouvernance et décision stratégique	Au moins un décideur habilité joignable et opérationnel à tout instant. Les décisions critiques sont rendues dans un délai maximum de 4 heures.	72 h	48 h	La gouvernance peut fonctionner de manière différée sur courte période. Au-delà de 72 h, le PCA ne peut être correctement activé et les arbitrages critiques sont bloqués.
P2 – Communication institutionnelle et gestion de crise	Au moins un canal de communication actif avec les autorités réglementaires et les partenaires clés. Une communication client doit être publiée dans les 2 heures suivant tout incident majeur.	4 h	2 h	Les obligations DORA imposent une notification aux autorités dans des délais stricts. Au-delà de 4 h sans communication, les rumeurs se propagent et la maîtrise de la crise devient très difficile.
P3 – Engagement contractuel et représentativité légale	Capacité à signer ou renouveler les contrats des prestataires essentiels (Azure, Orange Business, Stripe) dans les délais contractuels.	48 h	24 h	La rupture de contrats avec des prestataires essentiels entraînerait l'arrêt du SI en cascade. 48 h est le délai maximal avant impact contractuel critique.
Direction des Ressources Humaines (DRH)				

Processus	Niveau de service minimum	DIMA	RTO	Justification
P1 – Gestion de la paie et des contrats de travail	100 % des salaires versés dans les délais légaux (avant le 5 du mois). Aucun écart admissible en période critique (J-5 à J-1 avant échéance).	48 h (hors période de paie) / 4 h (en J-5 à J-1)	24 h / 2 h	Le non-paiement des salaires constitue une faute grave exposant Essential Bank à des litiges prud'homaux. La criticité est maximale en J-5 avant échéance. Hors période de paie, l'activité peut être différée 48 h sans impact légal immédiat.
P2 – Mobilisation des équipes en situation de crise	Au moins 60 % des effectifs sur les postes critiques (SI, agences, DAF) mobilisables dans les 2 heures suivant le déclenchement du PCA.	2 h	1 h	Sans effectif suffisant sur les postes critiques, les services bancaires ne peuvent être maintenus. 2 h est le seuil au-delà duquel l'impact sur les clients devient significatif.
P3 – Administration des ressources humaines courante	Traitement minimal des urgences administratives (arrêts maladie, décrets d'urgence). Les activités non urgentes peuvent être différées.	5 j ouvrés	3 j ouvrés	L'administration RH courante peut être suspendue 5 jours ouvrables sans impact légal ou opérationnel critique. Au-delà, les obligations administratives commencent à être compromises.
Direction Administrative et Financière (DAF)				
P1 – Trésorerie et règlements critiques	Paiement des prestataires critiques (Azure, Orange Business, Stripe) dans les délais contractuels. Aucun dépassement admissible pour les prestataires dont la suspension entraîne l'arrêt du SI.	24 h	8 h	Azure et Orange Business disposent de clauses de suspension rapide en cas de défaut de paiement. Une interruption de 24 h risque de déclencher la suspension des services cloud et réseau.
P2 – Reporting réglementaire Banque de France	Transmission d'au moins les reportings prioritaires dans les délais légaux imposés par la Banque de France. Aucun retard admissible sur les reportings prudentiels obligatoires.	24 h	8 h	Les obligations de reporting prudentiel sont soumises à des délais légaux stricts. Tout manquement expose Essential Bank à des sanctions financières et au risque de retrait de son agrément bancaire.
P3 – Comptabilité et contrôle de gestion	Maintien des enregistrements comptables essentiels	5 j ouvrés	3 j ouvrés	Les clôtures comptables mensuelles disposent de délais légaux plus longs

Processus	Niveau de service minimum	DIMA	RTO	Justification
	(recettes et dépenses). Les clôtures mensuelles peuvent être légèrement décalées sans impact légal immédiat.			(généralement 30 jours). Une interruption de 5 jours reste récupérable sans sanction, sous réserve d'un rattrapage dans les délais réglementaires.
Direction Marketing et Communication (Mktg / Com.)				
P1 – Gestion de la relation client (B2B et B2C)	Maintien d'au moins un canal de contact client opérationnel (téléphone ou email). Les réclamations urgentes sont traitées sous 12 heures maximum.	24 h	12 h	Au-delà de 24 h sans contact client, la frustration engendre des résiliations de comptes. 12 h est le délai réaliste pour rétablir un canal minimal via redirection téléphonique.
P2 – Communication de crise	Publication d'une première communication de crise dans les 2 heures suivant tout incident majeur, couvrant a minima les clients directement impactés.	2 h	1 h	En l'absence de communication rapide, les rumeurs et informations erronées se propagent sur les réseaux sociaux, amplifiant la crise. 2 h est le seuil critique au-delà duquel la maîtrise de la communication devient très difficile.
P3 – Campagnes d'acquisition et de fidélisation	Maintien des engagements marketing contractuels en cours. Les nouvelles campagnes peuvent être suspendues.	7 j	5 j	Les campagnes d'acquisition ne sont pas critiques à court terme. L'impact d'une interruption de 7 jours est faible sur les revenus immédiats. Les contrats marketing en cours peuvent être gérés avec un préavis contractuel.
Direction Informatique (DSI / RSSI / DPO)				
P1 – Exploitation et disponibilité du SI (core banking et APIs de paiement)	Maintien d'au moins 80 % des transactions (virements, consultations de comptes) traitées dans les délais normaux. Toute transaction initiée doit être enregistrée même en mode dégradé.	4 h	2 h	L'ensemble des services bancaires dépend du SI. Une interruption de 4 h entraîne une perte de revenus directe, une violation des SLA avec les clients B2B et une non-conformité au règlement DORA.
P2 – Gestion de la sécurité et réponse aux incidents (RSSI)	Maintien d'une surveillance minimale de sécurité : monitoring des	8 h	4 h	Sans surveillance de sécurité, une cyberattaque (rançongiciel, exfiltration)

Processus	Niveau de service minimum	DIMA	RTO	Justification
	accès critiques au SI, détection des anomalies sur les transactions financières.			peut se propager pendant des heures sans détection, conformément aux scénarios SO-01a et SO-03a de l'analyse EBIOS.
P3 – Sauvegarde, reprise et protection des données (DPO et PRA)	Restauration des données critiques (transactions, comptes) avec un Objectif de Point de Reprise (RPO) inférieur ou égal à 6 heures. Aucune perte de données client irréversible n'est admissible.	24 h	8 h	La perte définitive de données clients est juridiquement inacceptable. Azure effectue des instantanés toutes les 6 heures. Le PRA documenté permet une restauration complète en 8 heures. Au-delà de 24 h, les pertes commencent à compromettre l'intégrité des comptes.

DIMA = Durée d'Interruption Maximale Admissible | **RTO** = Recovery Time Objective (objectif de rétablissement)

II.3 Modes dégradés

Le mode dégradé permet de maintenir un niveau de service minimal lorsque les ressources normales sont indisponibles. Les processus éligibles ont été sélectionnés en raison de leur criticité et de la faisabilité technique d'une solution de substitution. Leur activation est décidée par le chef de projet PCA (DSI) après 30 minutes d'indisponibilité non résolue du processus primaire.

Processus	Description du mode dégradé	Limites et conditions de levée
P1 – Gouvernance et décision stratégique [DG]	Délégation de signature au DAF ou au DSI désigné suppléant. Réunions de crise par visioconférence. Décisions formalisées par messagerie sécurisée en attendant le rétablissement normal.	Capacité réduite et risque d'erreurs manuelles accrues. Le mode dégradé est levé dès le rétablissement du processus primaire, sur décision du DSI.
P2 – Communication institutionnelle et gestion de crise [DG]	Activation du kit de communication de crise pré-rédigé. Diffusion sur les réseaux sociaux (LinkedIn, site web) si la messagerie est indisponible. Utilisation des téléphones mobiles personnels de secours.	Capacité réduite et risque d'erreurs manuelles accrues. Le mode dégradé est levé dès le rétablissement du processus primaire, sur décision du DSI.
P1 – Gestion de la paie et des contrats de travail [DRH]	Traitement manuel des bulletins de paie sur poste de secours (fichiers Excel). Coordination directe avec la banque partenaire pour les virements prioritaires des salaires. Impression des bulletins en version papier.	Capacité réduite et risque d'erreurs manuelles accrues. Le mode dégradé est levé dès le rétablissement du processus primaire, sur décision du DSI.

Processus	Description du mode dégradé	Limites et conditions de levée
P1 – Trésorerie et règlements critiques [DAF]	Ordres de virement papier adressés directement à la banque partenaire. Priorisation des paiements critiques (Azure, Orange Business) sur les paiements secondaires. Accès bancaire par téléphone si la plateforme en ligne est indisponible.	Capacité réduite et risque d'erreurs manuelles accrues. Le mode dégradé est levé dès le rétablissement du processus primaire, sur décision du DSI.
P2 – Reporting réglementaire Banque de France [DAF]	Saisie manuelle des données sur les formulaires de secours ONEGATE. Transmission par courrier recommandé si le portail est indisponible. Contact téléphonique direct avec le correspondant Banque de France.	Capacité réduite et risque d'erreurs manuelles accrues. Le mode dégradé est levé dès le rétablissement du processus primaire, sur décision du DSI.
P1 – Gestion de la relation client (B2B et B2C) [Mktg / Com.]	Redirection des appels entrants vers un numéro de secours. Réponse automatique par email informant les clients du délai de traitement. Traitement prioritaire des réclamations par ordre d'urgence.	Capacité réduite et risque d'erreurs manuelles accrues. Le mode dégradé est levé dès le rétablissement du processus primaire, sur décision du DSI.
P1 – Exploitation et disponibilité du SI (core banking et APIs de paiement) [DSI / RSSI / DPO]	Basculement automatique vers l'environnement Azure de secours (failover). Mode lecture seule pour les consultations de comptes. Traitement différé des virements non urgents. Affichage d'un message d'information sur le portail en ligne.	Capacité réduite et risque d'erreurs manuelles accrues. Le mode dégradé est levé dès le rétablissement du processus primaire, sur décision du DSI.
P3 – Sauvegarde, reprise et protection des données (DPO et PRA) [DSI / RSSI / DPO]	Restauration depuis le dernier instantané Azure (toutes les 6 heures). Priorisation des restaurations : données de transactions et de comptes en premier, données marketing et RH en second. Notification immédiate à la CNIL si des données personnelles sont perdues.	Capacité réduite et risque d'erreurs manuelles accrues. Le mode dégradé est levé dès le rétablissement du processus primaire, sur décision du DSI.

II.4 Analyse d'impact sur l'activité (Business Impact Analysis)

L'Analyse d'Impact sur l'Activité (BIA) quantifie les conséquences d'une interruption de chaque processus et en évalue la gravité selon l'échelle définie dans l'analyse EBIOS Risk Manager d'Essential Bank : G4 Critique (existence menacée), G3 Élevé (forte dégradation), G2 Modéré (dégradation limitée), G1 Faible (impact négligeable).

Processus	Conséquences de l'interruption	Gravité	Réf. EBIOS
Gouvernance et décision stratégique [DG]	Blocage des décisions critiques, impossibilité d'activer le PCA officiellement, paralysie de l'organisation. Non-conformité DORA si la Direction Générale ne peut pas valider les plans de reprise.	G3 Élevé	SO-02a / SO-03b
Communication institutionnelle et gestion de crise [DG]	Aggravation de la crise par défaut d'information, perte de confiance des clients et des autorités, risque de sanctions Banque de France pour défaut de reporting d'incident.	G4 Critique	SO-01a / SO-03a
Engagement contractuel et représentativité légale [DG]	Rupture de contrats avec les prestataires cloud et de paiement. Arrêt potentiel de l'infrastructure Azure et des APIs Stripe et PayPal. Impact en cascade sur la totalité des services bancaires.	G3 Élevé	SO-02a / SO-03b
Gestion de la paie et des contrats de travail [DRH]	Litiges prud'homaux, démotivation des collaborateurs et risque de départ de profils clés en période de crise, aggravant le sous-effectif sur les postes critiques.	G3 Élevé	SO-02a / SO-03b
Mobilisation des équipes en situation de crise [DRH]	Sous-effectif sur les postes critiques, impossibilité de maintenir les services bancaires en mode dégradé, risque de fermeture non planifiée des agences.	G3 Élevé	SO-02a / SO-03b
Administration des ressources humaines courante [DRH]	Désorganisation RH à court terme, retards administratifs. Impact faible et récupérable rapidement sans conséquence opérationnelle majeure.	G1 Faible	—
Trésorerie et règlements critiques [DAF]	Suspension des services Azure (SI indisponible), arrêt des APIs de paiement Stripe et PayPal, coupure réseau Orange Business. Impact en cascade : arrêt total des services bancaires en ligne et des trois agences.	G4 Critique	SO-01a / SO-03a
Reporting réglementaire Banque de France [DAF]	Sanctions financières de la Banque de France, mise sous surveillance prudentielle renforcée, risque de retrait d'agrément bancaire en cas de manquements répétés.	G4 Critique	SO-01a / SO-03a
Comptabilité et contrôle de gestion [DAF]	Retard de clôture comptable, difficultés de pilotage financier, erreurs potentielles d'inventaire. Impact modéré et récupérable. Risque d'écarts de gestion si l'interruption se prolonge.	G2 Modéré	SO-04a
Gestion de la relation client (B2B et B2C) [Mktg / Com.]	Insatisfaction client, résiliation de comptes et départ vers des établissements concurrents,	G2 Modéré	SO-04a

Processus	Conséquences de l'interruption	Gravité	Réf. EBIOS
	détérioration de l'image de marque. Perte de revenus significative en contexte B2B.		
Communication de crise [Mktg / Com.]	Mauvais buzz médiatique irréversible, départs massifs de clientèle, perte de confiance des partenaires institutionnels. Dans le secteur bancaire, une gestion de crise défaillante peut conduire à une crise de liquidité par retraits massifs.	G4 <i>Critique</i>	SO-01a / SO-03a
Campagnes d'acquisition et de fidélisation [Mktg / Com.]	Perte limitée de nouveaux clients potentiels, retard d'acquisition commerciale. Impact modéré uniquement si l'interruption dépasse plusieurs semaines.	G1 <i>Faible</i>	—
Exploitation et disponibilité du SI (core banking et APIs de paiement) [DSI / RSSI / DPO]	Interruption totale des services bancaires (comptes, crédits, virements). Perte de revenus estimée entre 10 000 et 50 000 EUR par heure d'indisponibilité. Violation du règlement DORA. Risque de perte de données clients.	G4 <i>Critique</i>	SO-01a / SO-03a
Gestion de la sécurité et réponse aux incidents (RSSI) [DSI / RSSI / DPO]	Propagation silencieuse d'une cyberattaque, exfiltration de données clients (violation RGPD), chiffrement du SI par rançongiciel. Obligation de notification à la CNIL dans les 72 heures (article 33 RGPD). Sanctions pouvant atteindre 4 % du chiffre d'affaires mondial.	G4 <i>Critique</i>	SO-01a / SO-03a
Sauvegarde, reprise et protection des données (DPO et PRA) [DSI / RSSI / DPO]	Perte de données clients irréversible. Violation de l'article 5 du RGPD (intégrité et disponibilité des données). Obligation de notification à la CNIL et aux clients concernés sous 72 heures. Sanctions CNIL pouvant atteindre 20 millions EUR ou 4 % du chiffre d'affaires mondial.	G4 <i>Critique</i>	SO-01a / SO-03a

III. Identification et gestion des risques prioritaires

Ce troisième volet intègre au PCA d'Essential Bank les résultats de l'analyse de risques conduite selon la méthode EBIOS Risk Manager, référentiel national recommandé par l'ANSSI. L'analyse a été structurée en cinq ateliers : cadrage et socle de sécurité (Atelier 1), identification des sources de risques (Atelier 2), construction des scénarios stratégiques (Atelier 3), élaboration des scénarios opérationnels (Atelier 4) et traitement des risques (Atelier 5).

III.1 Présentation de l'analyse de risques EBIOS Risk Manager

L'analyse de risques a été conduite sur le périmètre complet du système d'information d'Essential Bank, couvrant les postes de travail, les serveurs hébergeant les applications métiers et les bases de données clients, le réseau informatique inter-agences (LAN et WAN), la connexion Internet, les accès distants et le logiciel de gestion financière (core banking). Les biens essentiels retenus sont les données personnelles des clients, les dossiers de crédit, les transactions financières et les informations internes de l'établissement.

Sources de risques identifiées (Atelier 2)

L'Atelier 2 vise à identifier et à caractériser les sources de risques susceptibles d'agir, intentionnellement ou non, contre les biens essentiels de l'organisation.

Catégorie	Source de risque	Motivation	Capacité estimée
Externe / Intentionnel	Cybercriminel externe	Gain financier	Moyenne à élevée
Interne / Intentionnel	Employé malveillant	Gain financier, vengeance	Moyenne (accès légitimes)
Interne / Non intentionnel	Employé négligent	Erreur, méconnaissance	Faible (mais fréquent)
Externe / Intentionnel	Fraudeur / Escroc	Fraude crédit, usurpation d'identité	Faible à moyenne

III.2 Identification et évaluation des risques (scénarios opérationnels)

Les scénarios opérationnels (Atelier 4) affinent les scénarios stratégiques en modes opératoires techniques détaillés. Ils sont évalués selon deux critères : la vraisemblance (probabilité d'occurrence, de 1 à 4) et la gravité (impact sur l'organisation, de G1 à G4). Le croisement de ces deux critères détermine le niveau de risque global.

Réf.	Scénario / Mode opératoire	Source de risque	Bien essentiel ciblé	Vraisemblance	Gravité	Niveau de risque
SO-01a	Hameçonnage ciblé → vol d'identifiants → exfiltration de données clients et transactions financières	Cybercriminel externe	Données personnelles clients, transactions financières	4 – Élevée	4 – Critique	Inacceptable
SO-02a	Accès non audité au core banking → modification	Employé malveillant	Dossiers de crédit,	3 – Moyenne	4 – Critique	Inacceptable

Réf.	Scénario / Mode opératoire	Source de risque	Bien essentiel ciblé	Vraisemblance	Gravité	Niveau de risque
	frauduleuse de dossiers → virement non autorisé		transactions financières			
SO-03a	Infection par rançongiciel via pièce jointe → chiffrement des serveurs → arrêt complet de l'activité	Cybercriminel externe	Disponibilité des services financiers (core banking)	3 – Moyenne	4 – Critique	Inacceptable
SO-03b	Panne matérielle du serveur central sans redondance → arrêt partiel des services bancaires	Panne technique / sinistre physique	Disponibilité des services financiers	3 – Moyenne	3 – Élevée	Important
SO-04a	Vol d'un poste de travail en agence → accès aux données clients locales non chiffrées	Opportuniste externe	Données clients stockées localement	2 – Faible	3 – Élevée	Modéré

Vraisemblance : 1 = Faible | 2 = Moyenne | 3 = Élevée | 4 = Très élevée **Gravité** : G1 = Faible | G2 = Modéré | G3 = Élevé | G4 = Critique

III.3 Traitement des risques

Pour l'ensemble des risques identifiés, la stratégie de traitement retenue est la réduction : des mesures de sécurité organisationnelles, techniques et physiques sont mises en œuvre afin de ramener chaque risque à un niveau résiduel acceptable. Le tableau ci-dessous détaille les mesures adoptées et le risque résiduel après traitement.

Réf.	Risque	Stratégie	Mesures de traitement	Risque résiduel / Acceptabilité
SO-01a	Hameçonnage et exfiltration de données	Réduction	- Déploiement d'un filtre anti-spam et anti-hameçonnage sur la messagerie (email gateway) - Authentification multifacteur (MFA) sur l'ensemble des accès applicatifs - Programme de sensibilisation annuel obligatoire avec simulation d'attaque - Journalisation des authentifications et alertes en cas de connexion anormale	Modéré <i>Acceptable</i>
SO-02a	Fraude interne sur les dossiers de crédit	Réduction	- Ségrégation des tâches : la saisie et la validation d'un dossier ne sont pas assurées par la même personne - Journalisation complète des accès et modifications dans le logiciel de gestion (core banking)	Faible <i>Acceptable</i>

Réf.	Risque	Stratégie	Mesures de traitement	Risque résiduel / Acceptabilité
			– Audits internes trimestriels sur les opérations sensibles – Recertification semestrielle des droits d'accès	
SO-03a	Infection par rançongiciel et indisponibilité du SI	Réduction	– Déploiement d'un EDR (Endpoint Detection & Response) en remplacement du simple antivirus – Plan de Reprise d'Activité (PRA) documenté et testé annuellement – Sauvegardes automatiques quotidiennes selon la règle 3-2-1 avec test de restauration mensuel – Segmentation réseau (VLAN) pour limiter la propagation latérale d'une infection	Modéré <i>Acceptable</i>
SO-03b	Panne matérielle et arrêt partiel des services	Réduction	– Solution de redondance serveur (virtualisation ou hébergement cloud Azure en haute disponibilité) – PRA avec bascule automatique (failover) documenté et testé – Test mensuel de la procédure de sauvegarde et de restauration	Faible <i>Acceptable</i>
SO-04a	Vol de poste de travail et accès aux données locales	Réduction	– Chiffrement des disques durs de tous les postes de travail (BitLocker ou équivalent) – Politique de sécurité des données locales formalisée dans la PSSI – Renforcement du contrôle d'accès physique dans les agences (badge, journal des entrées)	Faible <i>Acceptable</i>

L'ensemble des risques identifiés bénéficie d'une stratégie de réduction active. À l'issue du traitement, trois risques (SO-01a, SO-03a et SO-03b) présentent un risque résiduel modéré, jugé acceptable au regard des contraintes budgétaires d'une PME bancaire. Les deux risques restants (SO-02a et SO-04a) atteignent un niveau résiduel faible. La mise en œuvre de ces mesures fera l'objet d'un suivi annuel dans le cadre du plan d'amélioration continue du PCA.

IV. Conséquences des scénarios sur la disponibilité des ressources critiques

Ce quatrième volet évalue l'impact des scénarios de risques identifiés dans l'analyse EBIOS complétés par des scénarios physiques et environnementaux sur la disponibilité des ressources critiques d'Essential Bank. L'objectif est de hiérarchiser les scénarios prioritaires et de définir l'étendue de chaque sinistre pour orienter les stratégies de reprise.

IV.1 Quantification des effets des scénarios sur les ressources critiques

Le tableau ci-dessous croise chaque scénario de risque avec les ressources critiques d'Essential Bank identifiées en Section II. La note attribuée reflète l'intensité de l'impact du scénario sur la disponibilité de chaque ressource, selon l'échelle suivante : 1 = très faible, 2 = faible, 3 = fort, 4 = très fort.

Scénario	SI / Core banking	Réseaux et Télécom	Données clients	Ressources humaines	Prestataires critiques	Locaux et Sites	Ressources financières
SO-01a – Hameçonnage et exfiltration de données	3	1	4	2	2	1	3
SO-02a – Fraude interne sur les dossiers de crédit	2	1	4	3	1	1	4
SO-03a – Rançongiciel / chiffrement du SI	4	3	4	2	3	1	4
SO-03b – Panne matérielle du serveur central	4	2	3	2	3	1	3
SO-04a – Vol de poste de travail en agence	1	1	3	2	1	2	1
Arrêt électricité prolongé	4	3	2	3	3	4	3
Panne Telecom / Internet (Orange Business)	3	4	2	2	4	2	3
Crise sanitaire (pandémie / absences massives)	1	1	1	4	2	3	2

Scénario	SI / Core banking	Réseaux et Télécom	Données clients	Ressources humaines	Prestataires critiques	Locaux et Sites	Ressources financières
Catastrophe naturelle – Inondation (Bagnolet)	3	3	3	3	2	4	2
Incendie / Sinistre physique sur un site	4	3	3	3	2	4	3

Légende : **4 = Très fort** | **3 = Fort** | **2 = Faible** | **1 = Très faible** | **Fond bleu** = scénarios cyber (EBIOS RM) | **Fond mauve** = scénarios physiques et environnementaux

L'analyse du tableau révèle que les scénarios SO-03a (rançongiciel) et SO-03b (panne serveur) présentent les impacts les plus critiques sur la disponibilité du système d'information

IV.2 Étendue des sinistres par scénario

Pour chaque scénario identifié, l'étendue du sinistre est précisée selon trois dimensions complémentaires : le périmètre organisationnel impacté (directions et équipes concernées), la zone géographique affectée (siège, agences, ensemble du réseau), et les activités bancaires touchées. Cette cartographie permet d'anticiper les besoins en ressources humaines, matérielles et logistiques lors de l'activation du PCA.

Scénario	Périmètre organisationnel	Zone géographique	Activités bancaires touchées
SO-01a – Hameçonnage et exfiltration	DSI / RSSI – toutes directions utilisatrices du SI	Siège social (Bagnolet) et 3 agences	Gestion des comptes clients, transactions financières, conformité RGPD
SO-02a – Fraude interne (crédit)	DAF et Direction Générale – équipe de contrôle interne	Siège social (Bagnolet)	Instruction et validation des dossiers de crédit, reporting réglementaire Banque de France
SO-03a – Rançongiciel / chiffrement du SI	Organisation entière – toutes directions impactées	Siège + 3 agences (arrêt total des services numériques)	Toutes activités bancaires : comptes, crédits, virements, portail client, reporting
SO-03b – Panne matérielle du serveur central	DSI et ensemble des directions utilisatrices du core banking	Siège social et 3 agences (accès SI perturbé)	Core banking, gestion des transactions et virements, consultation des comptes
SO-04a – Vol de poste de travail en agence	Agence concernée et DSI (investigation forensique)	Agence locale (périmètre limité)	Gestion des données clients locales, accès aux comptes depuis ce poste
Arrêt électricité prolongé	Site(s) affecté(s) – toutes directions sur place	Agence(s) ou siège selon l'origine de la coupure	Toutes activités sur site (accueil client, transactions en agence, administration)
Panne Telecom / Internet (Orange Business)	Organisation entière – perte de connectivité inter-sites	Tous les sites du réseau Essential Bank	Transactions en ligne, virements, portail client, communication inter-directions
Crise sanitaire (pandémie / absences massives)	Organisation entière – réduction d'effectifs toutes directions	Tous sites (activation du plan de télétravail d'urgence)	Toutes activités avec capacité réduite : accueil client, gestion crédit, reporting
Catastrophe naturelle – Inondation (Bagnolet)	Site(s) en zone inondée – évacuation et relogement temporaire	Bagnolet et communes limitrophes (zone à risque inondation)	Accueil client en agence, accès aux locaux, archivage physique des documents

Scénario	Périmètre organisationnel	Zone géographique	Activités bancaires touchées
Incendie / Sinistre physique sur un site	Site sinistré – évacuation totale et activation cellule de crise	Site concerné (siège ou agence selon localisation du sinistre)	Toutes activités du site : accueil, administration, infrastructure locale

Cette analyse de l'étendue confirme que les scénarios cyber (SO-03a rançongiciel en tête) et certains sinistres physiques (crise sanitaire, panne Telecom) ont un impact sur l'organisation entière, justifiant la priorité de traitement établie dans la section III. À l'inverse, des scénarios tels que le vol de poste (SO-04a) ou l'inondation restent géographiquement circonscrits et peuvent être contenus par des mesures de continuité locales.

V. Formalisation des moyens et procédures

La formalisation des moyens et procédures constitue le cœur opérationnel du Plan de Continuité d'Activité d'Essential Bank. Elle traduit les résultats de l'analyse des risques (section III) et de l'évaluation des impacts (sections II et IV) en objectifs mesurables et en plans d'action concrets par ressource critique.

V.1 Définition des objectifs de continuité : DMIA, PRMA et PDMA

Trois indicateurs bornent les objectifs de continuité d'Essential Bank. La Durée Maximale d'Interruption Admissible (DMIA) fixe le temps maximum pendant lequel un processus peut être indisponible avant d'engendrer des conséquences irréversibles pour l'organisation. Le Point de Reprise Maximum Admissible (PRMA) désigne le moment le plus éloigné dans le passé à partir duquel les données doivent impérativement pouvoir être restituées, déterminant ainsi la fréquence minimale des sauvegardes. La Perte de Données Maximum Admissible (PDMA) quantifie le volume maximal de données ou de transactions qu'Essential Bank peut se permettre de perdre de manière définitive sans mettre en péril sa conformité réglementaire ou son activité.

Les valeurs ci-dessous ont été établies sur la base du BIA (section II.4) et des scores d'impact TP4 (section IV). La DMIA globale du PCA est fixée à 4 heures, correspondant au processus le plus critique (exploitation du SI). Le PRMA global est de 6 heures, aligné sur la fréquence des instantanés Azure. La PDMA globale est inférieure à 6 heures de transactions opérationnelles.

Processus essentiel	Direction	DMIA	PRMA (RPO)	PDMA
Exploitation et disponibilité du SI (core banking, APIs paiement)	DSI	4 h	6 h	< 6 h de transactions
Communication institutionnelle et gestion de crise	DG / Mktg	2 h	N/A	N/A
Trésorerie et règlements critiques (Azure, Orange, Stripe)	DAF	24 h	6 h	< 6 h de données financières
Reporting réglementaire Banque de France (ONEGATE)	DAF	24 h	24 h	0 – aucune perte admissible
Gestion de la sécurité et réponse aux incidents (RSSI)	DSI	8 h	N/A	N/A
Sauvegarde, reprise et protection des données (DPO / PRA)	DSI	24 h	6 h	0 – aucune perte client irréversible
Gestion de la paie et des contrats de travail	DRH	4 h (J-5 à J-1) / 48 h (hors période)	24 h	0 en période critique
Mobilisation des équipes en situation de crise	DRH	2 h	N/A	N/A

Processus essentiel	Direction	DMIA	PRMA (RPO)	PDMA
Gestion de la relation client (B2B et B2C)	Mktg / Com.	24 h	12 h	N/A

DMIA = Durée Maximale d'Interruption Admissible | **PRMA** = Point de Reprise Maximum Admissible (RPO) | **PDMA** = Perte de Données Maximum Admissible

V.2 Plans de continuité par ressource critique

En croisant les scénarios de risques retenus avec les scores d'impact établis en section IV, il est possible d'identifier les menaces prioritaires pesant sur chacune des sept ressources critiques d'Essential Bank et de définir les mesures de continuité correspondantes. Seuls les scénarios atteignant un score d'impact supérieur ou égal à 3 (fort ou très fort) sont traités pour chaque ressource. Les mesures proposées garantissent que les objectifs DMIA et PRMA définis en V.1 sont atteignables.

V.2.1 – Core banking / applications métier

Ressource 1 : Core banking / applications métier			
Scénario impactant	Score	Mesures de continuité proposées	Responsable(s)
SO-03a – Rançongiciel / chiffrement du SI	4	Basculement automatique (failover) vers l'environnement Azure de reprise dans la région secondaire. Mode dégradé en lecture seule pour les consultations de comptes. Restauration depuis le dernier instantané Azure (PRMA = 6 h). Test annuel du PRA incluant simulation de chiffrement.	DSI / RSSI
SO-03b – Panne matérielle du serveur central	4	Redondance serveur par virtualisation Azure (haute disponibilité). Procédure de bascule documentée avec RTO cible = 2 h. Test mensuel de la procédure de démarrage de l'environnement de secours.	DSI
Arrêt électricité prolongé	4	Onduleurs (UPS) sur tous les équipements réseau critiques et serveurs. Groupe électrogène de secours pour les sites principaux. Les serveurs Azure restent disponibles indépendamment de la coupure locale.	DSI / Logistique
Incendie / Sinistre physique	4	Infrastructure hébergée dans le cloud Azure (résilience physique assurée par Microsoft). Réplication des données sur une région Azure géographiquement distincte. Procédure de reprise sur site de substitution ou en télétravail.	DSI
SO-01a – Hameçonnage et exfiltration	3	Cloisonnement réseau (VLAN) pour limiter l'accès au core banking. MFA obligatoire pour tout accès applicatif. Révocation	DSI / RSSI

		immédiate des accès compromis selon la procédure de réponse aux incidents.	
Panne Telecom (Orange Business)	3	Routeur 4G/5G de secours sur chaque site pour maintenir l'accès aux APIs cloud (Azure, Stripe). Bascule automatique sur le lien de secours avec notification à Orange Business (SLA de rétablissement).	DSI

V.2.2 – Infrastructure réseau / Telecom

Ressource 2 : Infrastructure réseau / Telecom			
Scénario impactant	Score	Mesures de continuité proposées	Responsable(s)
Panne Telecom (Orange Business)	4	Contrat SLA Orange Business avec GTR (Garantie de Temps de Rétablissement) définie. Déploiement de routeurs 4G/5G de secours (un par site) avec bascule automatique. Test trimestriel du basculement sur le lien de secours.	DSI
SO-03a – Rançongiciel / chiffrement du SI	3	Segmentation VLAN pour isoler les équipements infectés et limiter la propagation. Règles de pare-feu bloquant les communications non autorisées entre segments. Procédure d'isolation réseau intégrée au plan de réponse aux incidents.	DSI / RSSI
Arrêt électricité prolongé	3	Onduleurs (UPS) dimensionnés pour 4 heures d'autonomie sur tous les équipements réseau actifs (switchs, routeurs, points d'accès Wi-Fi). Vérification semestrielle de l'état des batteries.	DSI / Logistique
Catastrophe naturelle – Inondation	3	Équipements réseau installés en hauteur (racks surélevés). Procédure d'évacuation des équipements portables en cas d'alerte inondation. Connectivité assurée par 4G depuis un site non sinistré.	DSI
Incendie / Sinistre physique	3	Câblage structuré protégé par goulottes ignifugées. Inventaire des équipements réseau critiques pour remplacement rapide. Fournisseur de matériel de réseau identifié avec délai de livraison < 24 h.	DSI

V.2.3 – Locaux / sites physiques

Ressource 3 : Locaux / sites physiques			
Scénario impactant	Score	Mesures de continuité proposées	Responsable(s)

SO-01a – Hameçonnage (données locales)	4	Chiffrement intégral des disques durs (BitLocker) sur tous les postes pour protéger les données locales en cas de prise de contrôle physique. Contrôle d'accès badge avec journal des entrées sur tous les sites.	DSI / RSSI
SO-02a – Fraude interne	4	Contrôle d'accès aux zones sensibles (salle serveur, archives) limité aux personnes habilitées. Vidéosurveillance dans les zones d'accueil et de traitement des opérations. Audit physique semestriel.	DSI / DRH
SO-03a – Rançongiciel	4	Infrastructure cloud Azure : les serveurs critiques ne sont pas physiquement localisés dans les agences. Réduction de l'empreinte physique locale pour limiter l'exposition à un sinistre de site.	DSI
Arrêt électricité prolongé	4	Convention de site de repli signée avec un espace de coworking à Bagnolet (capacité minimale : 10 postes de travail équipés). Activation en moins de 4 heures sur décision du responsable PCA.	DG / Logistique
Incendie / Sinistre physique	3	Plan d'évacuation affiché et exercice annuel obligatoire. Contrat d'assurance tous risques couvrant la valeur de remplacement du matériel. Convention de site de repli pour le siège et les agences sinistrées.	DG / DAF
Catastrophe naturelle – Inondation	3	Cartographie des risques d'inondation sur Bagnolet (PPRI). Archivage numérique des documents critiques sur Azure pour éliminer les archives physiques non remplaçables. Plan d'évacuation anticipée.	DG / DSI

V.2.4 – Ressources humaines

Ressource 4 : Ressources humaines			
Scénario impactant	Score	Mesures de continuité proposées	Responsable(s)
Crise sanitaire (pandémie / absences massives)	4	Plan de télétravail d'urgence pré-déployé : VPN, accès sécurisé aux applications métier depuis tout poste externe. Matrice de suppléance formalisée pour les 15 postes les plus critiques. Test annuel du plan de continuité RH.	DRH / DSI
Arrêt électricité prolongé	3	Redéploiement du personnel sur le site de repli (espace de coworking). Procédure de convocation d'urgence via annuaire de crise (contacts personnels, SMS de masse).	DRH / DG

		Décision de fermeture exceptionnelle d'agence si < 30 % d'effectif présent.	
SO-02a – Fraude interne	3	Procédure de suspension immédiate des droits d'accès en cas de soupçon. Entretien RH obligatoire avant toute réintégration. Communication interne de crise gérée par la DRH pour préserver la cohésion d'équipe.	DRH / DSI
Incendie / Catastrophe naturelle	3	Annuaire de crise actualisé trimestriellement (numéros personnels, suppléants désignés). Procédure d'appel en cascade testée semestriellement. Personnel formé aux procédures d'évacuation et de continuité.	DRH

V.2.5 – Données clients et transactions

Ressource 5 : Données clients et transactions			
Scénario impactant	Score	Mesures de continuité proposées	Responsable(s)
Panne Telecom (Orange Business)	4	Cache local sécurisé des données de consultation (lecture seule, synchronisé toutes les 6 h). Enregistrement différé des transactions en attente de rétablissement de la connectivité. PRMA = 6 h.	DSI / DPO
SO-03a – Rançongiciel / chiffrement du SI	3	Règle de sauvegarde 3-2-1 : 3 copies, 2 supports distincts (Azure + stockage chiffré local), 1 copie hors site (Azure région secondaire). Test de restauration mensuel avec validation DPO. PRMA = 6 h.	DSI / DPO
SO-03b – Panne matérielle du serveur central	3	Restauration depuis l'instantané Azure le plus récent (toutes les 6 h). Procédure de réconciliation des transactions en attente au moment de la panne. Notification client si transactions impactées.	DSI
Arrêt électricité prolongé	3	Données hébergées principalement dans Azure : la coupure électrique locale n'affecte pas les données dans le cloud. Procédure de journalisation manuelle des opérations réalisées en mode papier pendant la coupure.	DSI / DPO

V.2.6 – Prestataires et partenaires

Ressource 6 : Prestataires et partenaires			
Scénario impactant	Score	Mesures de continuité proposées	Responsable(s)

Arrêt électricité prolongé	4	SLA Azure garantissant 99,9 % de disponibilité mensuelle (crédit de service en cas de manquement). Contrat Orange Business avec GTR (Garantie de Temps de Rétablissement). Identification d'un prestataire de secours cloud (AWS ou OVH) pour basculement d'urgence.	DSI / DAF
Incendie / Sinistre physique	4	Clause de continuité de service dans les contrats prestataires (Azure, Stripe, Orange Business). Réplication des accès et configurations chez un prestataire secondaire identifié. Contact d'urgence prestataire disponible 24h/24.	DAF / DSI
Catastrophe naturelle – Inondation	4	Hébergement cloud multi-région : les prestataires Azure sont géographiquement distribués. Procédure de basculement vers APIs de paiement alternatives (PayPal si Stripe indisponible et inversement).	DSI
Crise sanitaire	3	Continuité contractuelle assurée par les SLA des prestataires cloud (Azure, Stripe, PayPal sont des services cloud mondiaux non affectés par une crise sanitaire locale). Vérification trimestrielle des clauses de continuité.	DAF

V.2.7 – Ressources financières

Ressource 7 : Ressources financières			
Scénario impactant	Score	Mesures de continuité proposées	Responsable(s)
SO-02a – Fraude interne (dossiers de crédit)	4	Contrôle dual (double validation) pour toute opération financière dépassant un seuil défini. Blocage immédiat des comptes suspects sur décision DG + DAF. Assurance fraude interne souscrite auprès d'un assureur bancaire.	DAF / DG
SO-03a – Rançongiciel / indisponibilité SI	4	Provision de trésorerie de secours : 3 mois de charges fixes disponibles sur un compte bancaire secondaire. Procédure de virements papier directs auprès de la banque partenaire pour les paiements critiques (Azure, Orange).	DAF
SO-01a – Hameçonnage et exfiltration	3	Assurance cyber-risques couvrant les pertes d'exploitation et les frais de notification CNIL. Vérification mensuelle des transactions suspectes via le logiciel	DAF / RSSI

		comptable. Blocage des accès bancaires en ligne compromis.	
SO-03b – Panne matérielle	3	Ordres de virement de secours pré-rédigés pour les prestataires critiques. Accès bancaire téléphonique configuré comme alternative à la plateforme en ligne. RTO pour l'accès aux ressources financières = 8 h.	DAF
Panne Telecom / Internet	3	Accès bancaire via lien 4G de secours pour maintenir les virements critiques. Procédure dégradée : ordres de virement SWIFT papier via courrier recommandé si la connectivité est totalement perdue.	DAF / DSI
Incendie / Sinistre physique	3	Documents financiers critiques (contrats, RIB, mandats) numérisés et sauvegardés sur Azure. Assurance tous risques couvrant la perte de revenus (pertes d'exploitation) pendant la durée du sinistre.	DAF

V.3 Estimation des coûts des mesures PCA

L'estimation des coûts ci-dessous donne un ordre de grandeur des investissements nécessaires à la mise en œuvre des mesures de continuité identifiées pour les sept ressources critiques d'Essential Bank. Les chiffres sont des estimations calibrées pour une structure de 30 employés et 3 sites, et devront être affinés lors de la phase de contractualisation. Les mesures sont classées par priorité de déploiement.

Mesure de continuité	Ressource(s) ciblée(s)	Type	Coût estimé	Priorité
Routeurs 4G/5G de secours (×3 sites) + abonnements data	Réseau / Core banking	Matériel + Abonnement	3 000 – 5 000 €/an	P1
Azure Disaster Recovery (réplication région secondaire)	Core banking / Données	Cloud (OpEx)	8 000 – 18 000 €/an	P1
Assurance cyber-risques (pertes exploitation + frais CNIL)	Finances / Données	Assurance	5 000 – 15 000 €/an	P1
EDR (Endpoint Detection & Response) – 30 postes	Core banking / Réseau	Logiciel (SaaS)	2 000 – 4 000 €/an	P1
Onduleurs (UPS) ×3 sites – autonomie 4 h sur équip. critiques	Réseau / Locaux	Matériel (CapEx)	3 000 – 6 000 € (achat)	P2
Convention espace de coworking (site de repli, 10 postes min.)	Locaux / RH	Contrat de service	500 – 1 500 €/mois	P2
Authentification multifacteur (MFA) – ensemble des accès	Core banking / Données	Logiciel (SaaS)	500 – 2 000 €/an	P2
Tests PRA annuels (prestation externe ou interne)	Toutes	Prestation	2 000 – 5 000 €/an	P2
Formation et simulation de phishing (sensibilisation annuelle)	RH / Données	Formation	1 500 – 3 000 €/an	P2
Contrat assurance tous risques locaux (pertes d'exploitation)	Locaux / Finances	Assurance	2 000 – 5 000 €/an	P3
Système de vidéosurveillance et contrôle d'accès badge ×3 sites	Locaux / Prestataires	Matériel (CapEx)	3 000 – 8 000 € (achat)	P3

Mesure de continuité	Ressource(s) ciblée(s)	Type	Coût estimé	Priorité
Provision de trésorerie de secours (3 mois de charges fixes)	Finances	Réserve financière	~50 000 € (à immobiliser)	P3

Priorité **P1 = Immédiat (< 3 mois)** | P2 = Court terme (3 – 6 mois) | P3 = Moyen terme (6 – 12 mois)

Le budget total estimé pour la mise en œuvre complète des mesures PCA d'Essential Bank s'établit entre 30 000 et 70 000 EUR la première année (incluant les investissements ponctuels en matériel), puis entre 25 000 et 55 000 EUR par an en régime de croisière. Rapporté aux pertes potentielles estimées en cas de sinistre majeur (10 000 à 50 000 EUR par heure d'indisponibilité du SI selon le BIA TP2), cet investissement présente un retour sur investissement positif dès le premier incident évité.

V.4 Plan d'action PCA

En complément du plan d'action issu de l'analyse de risques EBIOS (section III.3), un plan d'action spécifique au PCA est formalisé ci-dessous. Il reprend les mesures de continuité par ressource, les priorise selon l'urgence opérationnelle, identifie les responsables de mise en œuvre et fixe les délais d'exécution. Ce tableau constitue la feuille de route opérationnelle du PCA d'Essential Bank.

Réf.	Action PCA	Ressource ciblée	Responsable	Délai	Coût estimé	Statut
A-01	Déployer Azure Disaster Recovery (réplication région secondaire) et valider le basculement automatique (failover) du core banking avec RTO < 2 h	Core banking	DSI	< 3 mois	8–18 k€/an	À lancer
A-02	Souscrire une assurance cyber-risques couvrant les pertes d'exploitation, les frais de notification CNIL et les coûts de restauration du SI	Finances / Données	DAF	< 3 mois	5–15 k€/an	À lancer
A-03	Déployer un EDR (Endpoint Detection & Response) sur l'ensemble des 30 postes de travail pour remplacer l'antivirus simple	Core banking / Réseau	DSI / RSSI	< 3 mois	2–4 k€/an	À lancer
A-04	Installer des routeurs 4G/5G de secours sur les 3 sites avec bascule automatique en cas de panne Orange Business	Réseau	DSI	< 3 mois	3–5 k€/an	À lancer
A-05	Activer le MFA (authentification multifacteur) sur l'ensemble des accès applicatifs (core	Core banking / Données	DSI	< 3 mois	0,5–2 k€/an	À lancer

Réf.	Action PCA	Ressource ciblée	Responsable	Délai	Coût estimé	Statut
	banking, messagerie, SharePoint Azure)					
A-06	Signer une convention de site de repli avec un espace de coworking à Bagnolet (capacité : 10 postes équipés, activation < 4 h)	Locaux / RH	DG / DAF	3–6 mois	0,5–1,5 k€/mois	À lancer
A-07	Acquérir et installer des onduleurs (UPS) sur tous les équipements réseau actifs et serveurs locaux des 3 sites (autonomie min. 4 h)	Réseau / Locaux	DSI	3–6 mois	3–6 k€ (achat)	À lancer
A-08	Formaliser et tester le plan de télétravail d'urgence : VPN, listes d'accès, matrice de suppléance pour les 15 postes critiques	RH	DRH / DSI	3–6 mois	< 1 k€	À lancer
A-09	Réaliser un test complet de reprise d'activité (PRA) avec simulation de rançongiciel et mesure des temps de restauration (RTO réel vs cible)	Core banking / Données	DSI	3–6 mois	2–5 k€	À lancer
A-10	Organiser une formation de sensibilisation obligatoire avec simulation de phishing pour les 30 collaborateurs	RH / Données	RSSI / DRH	3–6 mois	1,5–3 k€	À lancer
A-11	Installer un système de contrôle d'accès badge et de vidéosurveillance dans les zones sensibles des 3 sites	Locaux / Prestataires	DG / DSI	6–12 mois	3–8 k€ (achat)	À lancer
A-12	Constituer une provision de trésorerie de secours représentant 3 mois de charges fixes (Azure, Orange, Stripe, paie) sur un compte dédié	Finances	DAF	6–12 mois	~50 k€ réserve	À lancer
A-13	Numériser et archiver sur Azure tous les documents financiers et contractuels critiques (contrats prestataires, RIB, mandats bancaires)	Finances / Données	DAF / DSI	6–12 mois	< 1 k€	À lancer

Priorité P1 (A-01 à A-05) = déploiement immédiat < 3 mois | **P2 (A-06 à A-10)** = court terme 3-6 mois | **P3 (A-11 à A-13)** = moyen terme 6-12 mois

Ce plan d'action PCA sera soumis à une revue semestrielle par le comité de pilotage composé du Directeur Général, du DSI, du RSSI et du DAF. Chaque action fera l'objet d'un point d'avancement mensuel pendant la phase de déploiement. La mise à jour du présent PCA sera réalisée annuellement ou après tout incident majeur ou changement organisationnel significatif.

VI. Stratégie de continuité

La stratégie de continuité d'Essential Bank formalise l'ordre d'activation des mesures identifiées dans les sections précédentes et fournit aux collaborateurs des fiches réflexes opérationnelles par métier. Elle répond à deux impératifs : garantir que les actions de reprise sont exécutées dans le bon ordre et dans les délais fixés par les objectifs DMIA, et s'assurer que chaque direction dispose d'une procédure claire et immédiatement applicable sans recours à ce document complet.

VI.1 Frise chronologique d'activation et ordre de priorité des mesures

La frise ci-dessous constitue la séquence de référence pour l'activation du PCA d'Essential Bank. Elle classe les actions par phase temporelle, de la détection initiale jusqu'au retour à la normale, en garantissant le respect des DMIA les plus contraignants (core banking = 4 h, communication de crise = 2 h). Chaque responsable de cellule de crise doit se référer à cette frise dès l'activation du plan.

Phase	Délai	Actions prioritaires	Responsable(s)
Phase 0 Alerte	T+0 à T+15 min	Détection de l'incident (SIEM, EDR, alerte physique, signalement collaborateur). Évaluation initiale de la gravité par le DSI ou RSSI. Décision préliminaire d'activation ou de surveillance renforcée. Notification immédiate au Directeur Général. Si cyberattaque détectée : isolation VLAN immédiate.	DSI / RSSI
Phase 1 Activation	T+15 à T+60 min	Activation officielle du PCA par le Directeur Général. Convocation de la cellule de crise (DG, DSI, DAF, DRH, Responsable Mktg). Déclenchement du basculement Azure DR si core banking indisponible. Activation du routeur 4G de secours si panne Telecom. Publication de la 1ère communication de crise clients (DMIA com. = 2 h). Alerte des responsables d'agences.	DG / DSI / Mktg
Phase 2 Stabilisation	T+1h à T+4h	Vérification du basculement core banking sur Azure DR (RTO cible : 2 h). Activation du mode dégradé sur les processus non rétablis. Déploiement du plan de télétravail d'urgence (DRH + DSI). Préparation des ordres de virement papier DAF pour les prestataires critiques. Si DMIA core banking (4 h) non atteint : escalade vers niveau de crise supérieur. Point de situation cellule de crise toutes les 30 minutes.	DSI / DG / DAF / DRH
Phase 3 Mode dégradé	T+4h à J+1	Fonctionnement en mode dégradé validé pour tous les processus hors DMIA critique. Traitement manuel des opérations bancaires prioritaires (virements critiques, paie si J-5). Communication client de suivi toutes les 2 heures. Si violation RGPD probable : ouverture du délai de 72 h pour notification CNIL (DPO). Reporting Banque de France si incident réglementaire (DMIA = 24 h).	Cellule de crise (tous)

Phase	Délai	Actions prioritaires	Responsable(s)
		Journalisation exhaustive de toutes les opérations en mode manuel.	
Phase 4 Reprise normale	J+1 à J+5	Restauration progressive des processus primaires selon ordre de priorité BIA. Validation de la cohérence des données restaurées avant remise en production (DPO + DSI). Réconciliation comptable et financière des opérations en mode dégradé (DAF). Communication de fin de crise aux clients et partenaires. Retour progressif sur site principal si site de repli activé. Levée officielle du mode PCA par le Directeur Général.	DSI / DPO / DAF / DG
Phase 5 RETEX	J+5 à J+30	Réunion de retour d'expérience (RETEX) obligatoire avec toute la cellule de crise. Analyse des écarts entre DMIA/PRMA cibles et résultats réels. Mise à jour du PCA sur la base des enseignements (procédures, contacts, ressources). Rapport d'incident à destination du comité de direction et, si requis, des autorités réglementaires. Planification du prochain test PRA.	DG / DSI / DAF / DRH

Codes couleur : **Phase 0** Urgence critique | **Phase 1** Activation | **Phase 2** Stabilisation | **Phase 3** Continuité dégradée | **Phase 4** Reprise | **Phase 5** RETEX

VI.2 Fiches réflexes / actions par métier

Les fiches réflexes ci-dessous sont conçues pour être utilisées directement par les collaborateurs dès l'activation du PCA, sans qu'il soit nécessaire de consulter l'intégralité du document. Chaque fiche précise les actions à exécuter selon la phase temporelle, les contacts d'urgence à mobiliser et les ressources de secours disponibles pour la direction concernée.

VI.2.1 – Fiche réflexe : Direction Générale (DG)

FICHE RÉFLEXE PCA DIRECTION GÉNÉRALE <i>Pilotage de la cellule de crise Décisions et gouvernance</i>		
Phase / Délai	Actions à réaliser	Contacts / Ressources
Alerte T+0 à T+15 min	Recevoir l'alerte du DSI ou RSSI. Évaluer la gravité initiale (question clé : le core banking est-il accessible ?). Décider de l'activation officielle du PCA ou d'une surveillance renforcée. Désigner le Responsable de la Cellule de Crise (RCC).	DSI, RSSI (appel direct)
Activation T+15 à T+60 min	Convoquer la cellule de crise (lieu de réunion de crise ou visioconférence d'urgence). Valider le niveau d'activation du PCA (partiel ou total). Autoriser la 1ère communication externe (via Mktg). Informer le conseil d'administration si l'incident est majeur.	DAF, DRH, DSI, Mktg (conférence de crise)
Stabilisation T+1h à T+4h	Présider les points de situation toutes les 30 minutes. Valider toutes les décisions engageant l'organisation (site de repli, fermeture d'agence, provision de trésorerie). Contacter la Banque de France si l'incident a un impact réglementaire.	Banque de France (correspondant prudentiel), BPI France si nécessaire
Mode dégradé T+4h à J+1	Assurer la gouvernance en mode dégradé : réunion de crise quotidienne. Valider les décisions financières d'urgence (usage provision trésorerie). Maintenir la communication institutionnelle. Prendre la décision de levée du PCA dès les conditions réunies.	Cellule de crise complète (DG, DSI, DAF, DRH, Mktg)
RETEX J+5 à J+30	Organiser et présider la réunion RETEX obligatoire. Valider et signer le rapport d'incident. Décider des mises à jour du PCA. Planifier le prochain exercice de test.	Comité de direction complet

VI.2.2 – Fiche réflexe : Direction Informatique (DSI / RSSI / DPO)

FICHE RÉFLEXE PCA DIRECTION INFORMATIQUE DSI / RSSI / DPO <i>Reprise technique du SI Sécurité Protection des données</i>		
Phase / Délai	Actions à réaliser	Contacts / Ressources
Alerte T+0 à T+15 min	Identifier la nature de l'incident (panne, cyberattaque, sinistre physique). Si cyberattaque : isoler immédiatement le périmètre impacté	SIEM / EDR (console interne), Azure Monitor,

	(isolation VLAN). Évaluer l'impact sur le core banking. Alerter DG. Si ransomware suspecté : couper les accès réseau inter-sites.	ANSSI CERT si cyberattaque
Activation T+15 à T+60 min	Déclencher le basculement Azure DR si core banking indisponible (procédure de failover documentée). Activer le routeur 4G de secours si panne Telecom Orange. Notifier toutes les directions utilisatrices. Créer un ticket d'incident avec horodatage.	Azure Support 24/7, Orange Business Numéro de crise, Équipe DSI
Stabilisation T+1h à T+4h	Superviser la reprise technique (RTO cible core banking = 2 h). Vérifier la cohérence des données restaurées. Activer le mode lecture seule si reprise complète impossible. Documenter chaque action avec timestamp. Si RGPD possiblement violé : notifier DPO pour ouvrir le délai de 72 h.	DPO (notification CNIL), Azure Support, CERT partenaire
Mode dégradé T+4h à J+1	Monitoring continu de la reprise. Test de cohérence des données restaurées avant remise en production. Si violation RGPD confirmée : préparer la notification CNIL (délai 72 h depuis détection). Journaliser toutes les actions de reprise pour le RETEX.	CNIL (en ligne), DPO, Azure Billing pour crédits SLA
Reprise normale J+1 à J+5	Valider la restauration complète des données (PRMA = 6 h). Réconcilier les transactions réalisées en mode dégradé. Mettre à jour les procédures PRA si des écarts ont été constatés. Préparer le rapport technique pour le RETEX.	DPO, Équipe DSI, Prestataires Azure / Orange

VI.2.3 – Fiche réflexe : Direction Administrative et Financière (DAF)

FICHE RÉFLEXE PCA DIRECTION ADMINISTRATIVE ET FINANCIÈRE DAF <i>Continuité financière Paiements critiques Reporting réglementaire</i>		
Phase / Délai	Actions à réaliser	Contacts / Ressources
Alerte T+0 à T+15 min	Évaluer les paiements critiques à effectuer dans les 24 heures (Azure, Orange Business, Stripe, paie si J-5 à J-1). Vérifier l'accès au logiciel comptable et à la banque en ligne. Identifier les opérations en cours qui pourraient être compromises.	Logiciel comptable, Banque partenaire (accès en ligne ou tel.)
Activation T+15 à T+60 min	Préparer les ordres de virement papier pour les prestataires critiques (Azure, Orange, Stripe). Contacter la banque partenaire pour activer les procédures d'urgence (virement par téléphone ou courrier). Informer les prestataires d'un éventuel retard de paiement.	Banque partenaire (numéro d'urgence), Azure Billing, Orange Business facturation
Stabilisation T+1h à T+4h	Exécuter les paiements prioritaires par procédure dégradée (virement papier, appel téléphonique	Banque de France (correspondant

	bancaire). Vérifier la provision de trésorerie de secours (compte dédié). Si DMIA reporting Banque de France < 24 h : préparer le reporting en mode dégradé (formulaires papier ONEGATE).	ONEGATE), Compte trésorerie de secours
Mode dégradé T+4h à J+1	Journaliser manuellement toutes les opérations financières avec horodatage. Assurer les virements de salaires si la période de paie est critique (J-5). Préparer la réconciliation comptable. Informer DG de tout risque de suspension de service prestataire.	Gestionnaire paie (procédure manuelle), Banque partenaire
Reprise normale J+1 à J+5	Réconcilier toutes les opérations manuelles avec le système comptable. Vérifier qu'aucun paiement critique n'a été manqué. Effectuer les rapports réglementaires en retard si nécessaire. Documenter les écarts financiers pour le RETEX.	Banque de France, commissaire aux comptes si nécessaire

VI.2.4 – Fiche réflexe : Direction des Ressources Humaines (DRH)

FICHE RÉFLEXE PCA DIRECTION DES RESSOURCES HUMAINES DRH		
<i>Mobilisation des équipes Suppléances Communication interne</i>		
Phase / Délai	Actions à réaliser	Contacts / Ressources
Alerte T+0 à T+15 min	Activer l'annuaire de crise (contacts personnels de tous les collaborateurs). Identifier les absences sur les postes critiques (DSI, agences, DAF). Prévenir le Directeur Général de la disponibilité des effectifs.	Annuaire de crise (version papier et numérique), Téléphones personnels
Activation T+15 à T+60 min	Lancer l'appel en cascade pour les postes critiques selon la matrice de suppléance. Activer le plan de télétravail d'urgence : confirmer les accès VPN pour les télétravailleurs. Organiser le transport vers le site de repli (espace de coworking) si les locaux sont inaccessibles.	Matrice de suppléance (document PCA), Prestataire VPN / DSI, Site de repli (convention)
Stabilisation T+1h à T+4h	Valider que les 15 postes critiques sont couverts (objectif : 60 % d'effectif en 2 h). Redéployer le personnel inter-agences si une agence est fermée. Envoyer un message d'information interne à tous les collaborateurs sur la situation et les consignes.	Responsables d'agences, DSI (accès à distance), Messagerie de secours
Mode dégradé T+4h à J+1	Gérer les demandes d'absences exceptionnelles liées à l'incident. Assurer la paie prioritaire si la période est critique. Maintenir une communication interne régulière (toutes les 2 h) pour éviter la démotivation. Gérer les cas de stress ou de difficultés psychologiques (médecine du travail).	Médecine du travail, Gestionnaire paie de secours, Cellule de crise
Reprise normale J+1 à J+5	Organiser le retour progressif sur site principal. Faire un bilan d'absentéisme et de redéploiement. Proposer un accompagnement RH post-incident si l'événement a été traumatisant. Contribuer au RETEX sur le volet humain.	Médecine du travail, DG, Ensemble des collaborateurs

VI.2.5 – Fiche réflexe : Direction Marketing et Communication

FICHE RÉFLEXE PCA DIRECTION MARKETING ET COMMUNICATION		
<i>Communication de crise Gestion de l'image Relation clients et partenaires</i>		
Phase / Délai	Actions à réaliser	Contacts / Ressources
Alerte T+0 à T+15 min	Activer le kit de communication de crise pré-rédigé. Identifier les canaux disponibles selon l'incident (site web, réseaux sociaux LinkedIn/X, email, SMS, téléphone). Évaluer si l'incident est	Kit de communication de crise (PDF pré-rédigé, disponible hors ligne)

	visible par les clients (SI down, agence fermée) ou interne.	
Activation T+15 à T+60 min	Rédiger et faire valider par DG la 1ère communication client (délai maximum : 2 h après l'incident). Message clair : incident en cours, équipes mobilisées, pas d'engagement de délai précis. Diffuser sur tous les canaux disponibles. Notifier les partenaires clés (BPI France, prestataires).	Approbation DG obligatoire, Réseaux sociaux, Site web (accès admin), Liste contacts partenaires
Stabilisation T+1h à T+4h	Mettre à jour la communication toutes les 2 heures avec les nouvelles informations disponibles. Gérer les appels entrants clients via le numéro de secours (renvoi activé). Surveiller les réseaux sociaux pour détecter et répondre aux commentaires négatifs. Préparer la communication de levée de crise.	Numéro de secours (renvoi activé par DSI), Outil de monitoring réseaux sociaux
Mode dégradé T+4h à J+1	Maintenir une communication client régulière. Personnaliser les messages pour les clients B2B impactés (email individuel si nécessaire). Coordonner avec DG pour la validation de tous les messages sortants. Éviter tout engagement de reprise qui ne soit pas confirmé par DSI.	Cellule de crise (validation DG), Liste clients B2B prioritaires
Reprise normale J+1 à J+5	Diffuser la communication de fin d'incident avec les mesures prises. Proposer des gestes commerciaux aux clients B2B les plus impactés (sur validation DG). Analyser l'impact sur l'image de marque. Contribuer au RETEX sur la gestion de la communication.	DG, DAF (gestes commerciaux), Outils de monitoring réputation

VI.2.6 – Fiche réflexe : Responsables d'agences (terrain)

FICHE RÉFLEXE PCA RESPONSABLES D'AGENCES OPÉRATIONS TERRAIN <i>Accueil client Procédures manuelles Sécurité du personnel et des locaux</i>		
Phase / Délai	Actions à réaliser	Contacts / Ressources
Alerte T+0 à T+15 min	Si incident physique (incendie, inondation, coupure électrique) : déclencher l'évacuation selon le plan affiché dans l'agence. Si incident SI : confirmer l'inaccessibilité du core banking avec DSI. Informer immédiatement les clients présents en agence.	Plan d'évacuation (affiché agence), DSI (hotline de crise), DG
Activation T+15 à T+60 min	Afficher le panneau d'information client à l'entrée de l'agence (modèle disponible dans le kit PCA). Basculer sur les procédures manuelles de traitement des opérations (carnet de bord papier). Rediriger les clients vers les agences opérationnelles ou le portail client si disponible.	Kit PCA agence (panneau d'info, carnet de bord, formulaires papier)

Stabilisation T+1h à T+4h	Si l'agence peut rester ouverte : maintenir un accueil minimum avec les procédures dégradées. Enregistrer toutes les opérations manuelles avec horodatage et signature client. Tenir informé le responsable PCA (DSI) de la situation locale toutes les heures.	DSI (point de situation), Formulaires d'opérations de secours (papier)
Mode dégradé / Fermeture T+4h à J+1	Si fermeture nécessaire : apposer le panneau de fermeture exceptionnelle avec coordonnées alternatives (agences voisines, numéro de secours, site web). Sécuriser les fonds et documents sensibles (coffre-fort). Redéployer le personnel vers une agence opérationnelle (coordination DRH). Signaler tout incident physique à l'assureur.	DRH (redéploiement), DAF (sécurisation des fonds), Assureur (sinistre physique)
Reprise normale J+1 à J+5	Vérifier l'état des locaux avant réouverture (électricité, réseau, matériel). Resaisir dans le SI les opérations manuelles réalisées pendant la période dégradée. Informer les clients de la reprise de service. Contribuer au RETEX sur les difficultés rencontrées en agence.	DSI (resaisie opérations), DG (validation réouverture), Clients de l'agence

L'ensemble de ces fiches réflexes doit être imprimé et conservé dans le kit PCA physique disponible dans chaque agence et au siège social d'Essential Bank. Elles sont conçues pour être utilisables même en l'absence d'accès au système d'information. Une révision de leur contenu est prévue semestriellement ou après chaque exercice de simulation de crise.